SUP'COM

INDP3 Cysed – Sécurité Applicative

SECUREPROOF

Recueil des besoins

Exigences fonctionnelles et exigences de sécurité
(Security Requirements Engineering)

Version : 1.0 (séance 1)
Équipe : 1.0 Trinôme n° 2
Document associé : `docs/cahier_des_charges.pdf`

FOURATI Mahmoud
ABDELHEDI Mohamed
IBEN ROMDHANE Rayen

Année universitaire 2026–2027

Table des matières

1 Introduction **3**

2 Justification de l'approche SRE **4**
2.1 Pourquoi une approche dédiée 4
2.2 Méthodes retenues 4
2.3 Méthodes non retenues 5
2.4 Les 9 étapes de SQUARE appliquées 5

3 Définitions, objectifs et actifs **6**
3.1 Glossaire 6
3.2 Objectifs de sécurité 6
3.3 Actifs 6

4 Acteurs et attaquants **8**

5 Exigences fonctionnelles **9**

6 Cas d'abus **11**

7 Arbres d'attaques **13**
7.1 Objectif racine : accuser un destinataire à tort, ou empêcher d'identifier le fuiteur 13
7.2 Objectif racine : obtenir un document sans autorisation 13

8 Analyse des risques **15**

9 Exigences de sécurité **16**
9.1 Identification et authentification 16
9.2 Autorisation et contrôle d'accès 17
9.3 Intégrité des données de traçabilité 17
9.4 Confidentialité des données 18
9.5 Traitement des documents (stéganographie, watermarking) 18
9.6 Non-répudiation et fiabilité de l'attribution 19
9.7 Audit et détection d'intrusions 19
9.8 Protection de l'application web 20
9.9 Résilience et disponibilité 20

10 Traçabilité des exigences **22**
10.1 Récits d'abus (backlog) 22

11 Gestion et maintenance des exigences **23**
11.1 Cycle de vie 23
11.2 Évolution selon l'agenda du cours 23
11.3 Inspection (SQUARE, étape 9) 23
11.4 Historique des versions 23

1 Introduction

Ce document recense les besoins de SecureProof, plateforme de protection et de traçabilité de documents PDF confidentiels par stéganographie, watermarking et fingerprinting (voir le cahier des charges). Il contient :

— la justification de l'approche d'ingénierie des exigences de sécurité retenue ;

— les exigences fonctionnelles ;

— les cas d'abus, arbres d'attaques et l'analyse des risques ;

— les exigences de sécurité détaillées, identifiées et vérifiables ;

— la traçabilité et la gestion de l'évolution des exigences.

Le document est vivant : il évolue au fil des séances (chapitre 11).

Notation. Priorité : **M** = Must, **S** = Should, **C** = Could. Les identifiants suivent le schéma `SEC-<catégorie>-<numéro>`.

2 Justification de l'approche SRE

Dans ce document, SRE désigne le *Security Requirements Engineering* : l'ingénierie des exigences de sécurité.

2.1 Pourquoi une approche dédiée

SecureProof protège des actifs dont la valeur est la confidentialité des documents et la fiabilité de la traçabilité. Deux particularités orientent la démarche :

— **Le destinataire légitime est un attaquant potentiel.** Le scénario central est la fuite par un utilisateur autorisé : les exigences ne peuvent donc pas se limiter à bloquer les intrus.

— **Les preuves produites doivent être fiables.** Un identifiant caché, un hash ou un journal falsifiés conduiraient à accuser à tort un destinataire. L'intégrité des données de traçabilité est aussi critique que la confidentialité des documents.

Traiter la sécurité après coup entraînerait des refontes coûteuses (modèle de données, gestion des clés, format des journaux). L'approche **Shift-Left** place donc la sécurité dès la conception.

2.2 Méthodes retenues

Méthode	**Rôle dans le projet**	**Livrable**
SQUARE	Squelette du processus : définitions, objectifs, actifs, élicitation, catégorisation, priorisation, inspection.	Chapitres 3 à 8
Cas d'abus (Misuse Cases)	Décrire ce que l'attaquant ne doit pas pouvoir faire, puis en déduire des exigences.	Chapitre 5
Arbres d'attaques	Décomposer les objectifs de l'attaquant sur les actifs les plus critiques.	Chapitre 6
Matrice de risques	Prioriser les exigences (vraisemblance × impact).	Chapitre 7

Méthode	Rôle dans le projet	Livrable
Récits d'abus / sécurité	Intégrer les exigences au backlog GitHub avec des critères d'acceptation.	Chapitre 10

2.3 Méthodes non retenues

— **OCTAVE et SERA :** orientées évaluation organisationnelle et chaînes de mission ; disproportionnées pour une application développée par une équipe de deux ou trois personnes.

— **UMLsec / SecureUML :** nécessitent un outillage d'ingénierie dirigée par les modèles absent du projet. Des diagrammes de séquence annotés pourront néanmoins documenter les flux sensibles.

2.4 Les 9 étapes de SQUARE appliquées

N°	Étape SQUARE	Application à SecureProof
1	Accord sur les définitions	Glossaire (chapitre 3)
2	Objectifs de sécurité	Chapitre 3 : C, I, D, traçabilité
3	Développer des artefacts	Actifs, acteurs, cas d'abus, arbres d'attaques
4	Évaluation des risques	Matrice de risques (chapitre 8)
5	Choix des techniques d'élicitation	Cas d'abus, arbres d'attaques, revue des menaces OWASP
6	Élicitation des exigences	Chapitres 6 et 9
7	Catégorisation	Par catégorie de sécurité et par composant
8	Priorisation	Priorités M/S/C dérivées du score de risque
9	Inspection	Revue croisée et tests associés (chapitre 11)

3 Définitions, objectifs et actifs

3.1 Glossaire

Document original : PDF importé avant tout traitement.

Version protégée : original après insertion de l'UUID.

Copie distribuée : version protégée après watermark et fingerprint pour un destinataire.

UUID stéganographique : identifiant aléatoire dissimulé dans le document, servant de clé de recherche en base.

Hash de référence : SHA-256 enregistré d'une version.

Attribution technique : rattachement d'un document suspect à une distribution avec un niveau de confiance.

3.2 Objectifs de sécurité

ID	Propriété	Objectif
OS-1	Confidentialité	Seuls les utilisateurs autorisés accèdent aux documents, aux copies et à la table fingerprint/destinataire.
OS-2	Intégrité	Documents, hashes de référence, associations UUID/hash et journaux ne sont modifiables que par les composants autorisés, toute altération étant détectable.
OS-3	Disponibilité	Authentification, distribution et analyse restent utilisables ; les données de traçabilité survivent à un incident.
OS-4	Non-répudiation (technique)	Toute action sensible est imputable à une identité authentifiée.
OS-5	Fiabilité de l'attribution	Une attribution n'est jamais présentée comme certaine ; elle porte un niveau de confiance.

3.3 Actifs

ID	Actif	Propriété critique	Justification
A1	Documents originaux	C, I	Contenu confidentiel
A2	Copies distribuées	C, I	Portent les marqueurs individuels
A3	Table fingerprint ↔ destinataire	C, I	Révèle ou fausse l'attribution
A4	UUID, hashes de référence	I	Base de la vérification d'intégrité
A5	Clés (HMAC, signature, chiffrement)	C, I	Compromission = falsification possible
A6	Journal d'audit	I, D	Base des investigations
A7	Comptes et sessions	C, I	Porte d'entrée de toutes les actions
A8	Service de traitement PDF	D, I	Surface d'attaque (fichiers non fiables)

4 Acteurs et attaquants

Acteur	**Type**	**Capacités**
Administrateur	Légitime	Gère comptes, rôles, consulte l'audit
Émetteur	Légitime	Importe, distribue, vérifie
Destinataire	Légitime	Télécharge sa copie
Attaquant externe	Malveillant	Accès réseau, aucun compte ; attaques web classiques
Destinataire malveillant	Malveillant	Compte valide, possède sa copie ; peut l'altérer, la convertir, la partager
Destinataires colludants	Malveillant	Comparent leurs copies pour repérer et effacer les marqueurs
Insider privilégié	Malveillant	Administrateur ou accès base ; peut altérer hashes et journaux

5 Exigences fonctionnelles

ID	Exigence	Prio
EF-01	Le système permet à un utilisateur enregistré de s'authentifier.	M
EF-02	L'administrateur crée, modifie, désactive des comptes et attribue un rôle.	M
EF-03	Le système permet d'importer un document PDF.	M
EF-04	Le système calcule le SHA-256 du document original.	M
EF-05	Le système génère un UUID unique par document importé.	M
EF-06	Le système dissimule l'UUID dans le PDF par stéganographie.	M
EF-07	Le système calcule et enregistre le SHA-256 de la version protégée.	M
EF-08	Le système extrait l'UUID d'un document soumis.	M
EF-09	Le système retrouve l'enregistrement à partir de l'UUID extrait.	M
EF-10	Le système compare le hash du fichier soumis au hash de référence et rend l'un des 4 résultats : intègre, modifié, identifiant inconnu, non extractible.	M
EF-11	L'émetteur sélectionne un ou plusieurs destinataires pour un document.	M
EF-12	Le système insère un watermark invisible dans chaque copie.	M
EF-13	Le système génère un fingerprint unique par distribution et l'associe au destinataire, au document et à la date.	M
EF-14	Le système calcule et enregistre le SHA-256 de chaque copie finale.	M
EF-15	Le destinataire télécharge uniquement la copie qui lui est attribuée.	M
EF-16	L'émetteur révoque l'accès futur à une distribution.	S
EF-17	Le rapport classe le résultat : confirmé, probable ou non concluant.	M
EF-18	Le système affiche l'historique des distributions et des vérifications.	S
EF-19	Le système permet la consultation filtrée du journal d'audit.	M
EF-20	Le tableau de bord présente des indicateurs de traçabilité par rôle.	S

Extension trinôme.

ID	Exigence	Prio
EF-T1	Une seconde technique de stéganographie PDF est implémentée et comparée à la première.	M
EF-T2	Un rapport de robustesse chiffré couvre recompression, conversion, impression/numérisation, suppression des métadonnées.	M
EF-T3	L'UUID est authentifié par HMAC-SHA-256 ou signature, avec rotation des clés.	M
EF-T4	Le système corrèle plusieurs marqueurs avec l'historique de distribution et exporte un rapport en PDF.	S

6 Cas d'abus

ID	Attaquant	Abus	Actif	Exigences induites
MC-01	Externe	Force brute ou bourrage d'identifiants sur la connexion	A7	SEC-AUTH-02, 03
MC-02	Utilisateur légitime	Accéder à la copie d'un autre destinataire en modifiant l'identifiant dans l'URL (IDOR)	A2, A3	SEC-AUTHZ-02, 03
MC-03	Destinataire	Supprimer ou altérer l'UUID et le watermark (conversion, retouche) pour empêcher l'attribution	A2, A4	SEC-DOC-06, SEC-INT-03
MC-04	Destinataire	Copier l'UUID d'un document dans un autre pour usurper une identité	A4	SEC-INT-02, 03
MC-05	Destinataires colludants	Comparer leurs copies pour localiser et effacer les marqueurs	A2, A3	SEC-DOC-07
MC-06	Externe	Téléverser un PDF piégé (bombe de décompression, JavaScript actif, PDF malformé)	A8	SEC-DOC-01 à 05
MC-07	Insider	Modifier un hash de référence ou une association en base	A4, A3	SEC-INT-01, 04
MC-08	Insider	Modifier ou effacer des lignes du journal	A6	SEC-AUD-02, 03
MC-09	Externe	Saturer l'API ou l'analyse par des requêtes ou fichiers volumineux	A8	SEC-RES-01, 02

ID	Attaquant	Abus	Actif	Exigences induites
MC-10	Externe	Voler une session par XSS ou CSRF	A7	SEC-WEB-01 à 04
MC-11	Insider	Extraire les clés du code ou du dépôt	A5	SEC-DATA-04
MC-12	Analyste ou externe	Faire accuser à tort un destinataire en présentant une correspondance faible comme certaine	A3	SEC-NR-03

7 Arbres d'attaques

7.1 Objectif racine : accuser un destinataire à tort, ou empêcher d'identifier le fuiteur

R1 Empêcher l'attribution d'une fuite (OU)

- R1.1 Détruire les marqueurs dans la copie (OU)
  - R1.1.1 Conversion ou recompression du PDF → SEC-DOC-06, EF-T2
  - R1.1.2 Impression puis numérisation → SEC-DOC-06
  - R1.1.3 Collusion et comparaison des copies → SEC-DOC-07
- R1.2 Corrompre les données de référence (OU)
  - R1.2.1 Modifier la table fingerprint/destinataire en base → SEC-INT-01, 04
  - R1.2.2 Voler les clés HMAC/signature → SEC-DATA-04, 05
  - R1.2.3 Se faire passer pour un administrateur → SEC-AUTH-01 à 06
- R1.3 Effacer les traces (ET)
  - R1.3.1 Obtenir un accès privilégié à la base → SEC-AUTHZ-04
  - R1.3.2 Modifier ou supprimer le journal → SEC-AUD-02, 03

R2 Faire attribuer à tort un document (OU)

- R2.1 Copier l'UUID d'un document dans un autre → SEC-INT-02, 03
- R2.2 Ajouter de faux marqueurs d'un autre destinataire → SEC-NR-03
- R2.3 Exploiter un rapport présentant une correspondance faible comme certaine → SEC-NR-03

7.2 Objectif racine : obtenir un document sans autorisation

R3 Accéder à un document confidentiel (OU)

- R3.1 Compromettre un compte (OU)
  - R3.1.1 Force brute / bourrage d'identifiants → SEC-AUTH-02, 03
  - R3.1.2 Vol de session (XSS, CSRF) → SEC-WEB-01 à 04
- R3.2 Contourner le contrôle d'accès (OU)
  - R3.2.1 IDOR sur l'identifiant de document → SEC-AUTHZ-02, 03

    - R3.2.2 Traversée de chemin dans le stockage → SEC-DOC-08
- R3.3 Lire le stockage directement → SEC-DATA-02, 03

8 Analyse des risques

Échelles : vraisemblance V et impact I de 1 (faible) à 5 (critique). Score $= V \times I$. Niveau : 1–6 faible, 8–12 moyen, 15–25 élevé. Priorité des exigences : élevé → M, moyen → M ou S, faible → S ou C.

Réf.	**Risque**	**V**	**I**	**Score**	**Niveau**
MC-01	Compromission de compte par force brute	4	4	16	Élevé
MC-02	Accès à la copie d'un autre (IDOR)	4	5	20	Élevé
MC-03	Suppression des marqueurs par le destinataire	4	4	16	Élevé
MC-04	Usurpation d'UUID	3	4	12	Moyen
MC-05	Collusion entre destinataires	3	3	9	Moyen
MC-06	PDF piégé	4	5	20	Élevé
MC-07	Altération des hashes en base	2	5	10	Moyen
MC-08	Altération du journal	2	4	8	Moyen
MC-09	Déni de service	3	3	9	Moyen
MC-10	Vol de session (XSS/CSRF)	3	4	12	Moyen
MC-11	Fuite des clés	2	5	10	Moyen
MC-12	Fausse accusation (attribution surestimée)	3	5	15	Élevé

9 Exigences de sécurité

Les valeurs indiquées sont des cibles initiales, révisables après étude technique. Colonne *Vérification* : T = test automatisé, R = revue de code/configuration, E = essai manuel ou expérimental.

9.1 Identification et authentification

ID	Exigence	Prio	Vérification
SEC-AUTH-01	Chaque compte possède un identifiant unique ; aucun compte partagé n'est autorisé.	M	T : unicité en base
SEC-AUTH-02	Les mots de passe sont hachés avec Argon2id (ou, à défaut, PBKDF2-HMAC-SHA-256 $\geq$ 600 000 itérations) avec un sel unique de 16 octets minimum.	M	R : configuration ; T : sel distinct
SEC-AUTH-03	Après 5 échecs consécutifs en 15 minutes, le compte est verrouillé 15 minutes et un événement est journalisé. Le message d'erreur ne révèle pas si l'identifiant existe.	M	T : 6 tentatives, message identique
SEC-AUTH-04	Longueur minimale du mot de passe : 12 caractères ; refus des mots de passe d'une liste de mots de passe courants.	M	T
SEC-AUTH-05	Session : expiration après 15 minutes d'inactivité et 8 heures au maximum ; identifiant de session régénéré à la connexion.	M	T : réutilisation d'un ancien identifiant refusée
SEC-AUTH-06	Le cookie de session porte les attributs HttpOnly, Secure et SameSite=Strict (ou Lax justifié).	M	R/E : inspection des en-têtes
SEC-AUTH-07	Les opérations d'administration et de révocation exigent une réauthentification de moins de 5 minutes.	S	T
SEC-AUTH-08	Authentification multifacteur (TOTP) pour les administrateurs et analystes.	C	E

9.2 Autorisation et contrôle d'accès

ID	Exigence	Prio	Vérification
SEC-AUTHZ-01	Quatre rôles (ADMIN, EMETTEUR, DESTINATAIRE, ANALYSTE) ; toute ressource REST déclare ses rôles autorisés ; refus par défaut.	M	R : annotations ; T : matrice rôle/endpoint
SEC-AUTHZ-02	Chaque accès à un document ou une copie vérifie côté serveur l'appartenance (propriétaire ou destinataire désigné) en plus du rôle.	M	T : un utilisateur A reçoit 403/404 sur la ressource de B
SEC-AUTHZ-03	Les identifiants exposés par l'API sont des UUID non séquentiels ; la réponse pour une ressource non autorisée ne révèle pas son existence (404).	M	T
SEC-AUTHZ-04	Le compte de base de données de l'application dispose des droits minimaux (pas de DDL, pas de suppression sur les tables d'audit).	M	R
SEC-AUTHZ-05	Seuls ANALYSTE et ADMIN accèdent à l'analyse et à la table fingerprint/destinataire ; un destinataire ne voit jamais son fingerprint.	M	T
SEC-AUTHZ-06	Un accès révoqué est refusé dès la requête suivante.	S	T

9.3 Intégrité des données de traçabilité

ID	Exigence	Prio	Vérification
SEC-INT-01	Les hashes de référence sont inscrits une seule fois à la création (aucune mise à jour applicative) ; toute modification est tracée.	M	T : tentative de UPDATE refusée
SEC-INT-02	L'UUID est généré par un générateur cryptographiquement sûr (UUID v4 via `SecureRandom`).	M	R
SEC-INT-03	L'association UUID ↔ hash est protégée par HMAC-SHA-256 (clé distincte des autres usages) ; la vérification contrôle le HMAC avant le hash.	M	T : enregistrement altéré détecté

ID	Exigence	Prio	Vérification
SEC-INT-04	Chaque enregistrement fingerprint/destinataire porte un HMAC vérifié à chaque lecture ; en cas d'échec : alerte et refus.	S	T
SEC-INT-05	La vérification distingue explicitement les 4 résultats et n'utilise jamais « intègre » si l'extraction a échoué.	M	T : 4 cas de test

9.4 Confidentialité des données

ID	Exigence	Prio	Vérification
SEC-DATA-01	Tout échange est chiffré en TLS 1.3 (TLS 1.2 minimum) ; HSTS activé ; HTTP redirigé ou refusé.	M	E : scan TLS
SEC-DATA-02	Les PDF sont stockés hors du répertoire servi par le serveur web, sous un nom aléatoire ; aucun accès direct par URL.	M	T/E
SEC-DATA-03	Les PDF au repos sont chiffrés (AES-256-GCM) avec une clé hors du dépôt de code et de la base.	S	R
SEC-DATA-04	Aucun secret (clé, mot de passe) dans le code source ou l'historique Git ; secrets fournis par variables d'environnement ou coffre. Analyse de secrets dans la CI.	M	R : outil de détection de secrets
SEC-DATA-05	Les clés sont versionnées (identifiant de clé enregistré) pour permettre la rotation sans invalider les anciens enregistrements.	S	R/T
SEC-DATA-06	Ni l'UUID ni le fingerprint ne contiennent de donnée personnelle ; aucune donnée sensible dans les journaux ou les réponses d'erreur.	M	T : inspection des logs

9.5 Traitement des documents (stéganographie, watermarking)

ID	Exigence	Prio	Vérification
SEC-DOC-01	Taille maximale : 20 Mo et 200 pages ; au-delà, rejet avant traitement.	M	T

ID	Exigence	Prio	Vérification
SEC-DOC-02	Le type est validé par la signature du fichier (`%PDF-`), pas par l'extension ni le type MIME déclaré.	M	T : fichier renommé rejeté
SEC-DOC-03	Les PDF contenant JavaScript, fichiers incorporés ou actions de lancement sont rejetés ou neutralisés ; aucun contenu actif n'est exécuté à l'extraction.	M	T : jeu de PDF piégés
SEC-DOC-04	Le traitement s'exécute avec un délai maximal de 30 s, une limite de mémoire et un compte système sans droit d'écriture hors de son répertoire de travail.	M	T/R
SEC-DOC-05	Les fichiers soumis à l'analyse sont traités comme non fiables avec les mêmes contrôles que l'importation.	M	T
SEC-DOC-06	La robustesse du watermark est mesurée sur au moins 4 transformations ; le taux de détection est publié dans le rapport de test.	S	E : campagne d'essais
SEC-DOC-07	Les fingerprints sont conçus pour résister à la comparaison de 2 copies (variation répartie dans le document, non localisée).	S	E
SEC-DOC-08	Les noms de fichiers fournis par l'utilisateur ne servent jamais à construire un chemin de stockage.	M	T : `../` refusé

9.6 Non-répudiation et fiabilité de l'attribution

ID	Exigence	Prio	Vérification
SEC-NR-01	Toute action sensible (import, distribution, révocation, analyse, administration) est associée à l'identité authentifiée de l'acteur.	M	T
SEC-NR-02	Les rapports d'analyse sont horodatés et leur hash est enregistré dans le journal.	S	T
SEC-NR-03	Un rapport indique « confirmé » seulement si UUID et fingerprint concordent et que leurs HMAC sont valides ; sinon « probable » ou « non concluant ». Le rapport mentionne que l'attribution est technique.	M	T : cas limites

9.7 Audit et détection d'intrusions

ID	Exigence	Prio	Vérification
SEC-AUD-01	Chaque événement journalise : acteur, action, ressource, résultat, date UTC, adresse IP, identifiant de requête.	M	T
SEC-AUD-02	Le journal est en ajout seul : l'application n'a aucun droit de modification ou suppression.	M	T/R
SEC-AUD-03	Chaînage cryptographique : chaque entrée contient le hash de la précédente ; une vérification périodique détecte toute rupture.	S	T : entrée modifiée détectée
SEC-AUD-04	Une alerte est émise après 10 refus d'accès (403/401) d'un même compte ou IP en 5 minutes, ou après tout échec de vérification de HMAC.	M	T
SEC-AUD-05	Les événements d'audit sont conservés 12 mois.	S	R

9.8 Protection de l'application web

ID	Exigence	Prio	Vérification
SEC-WEB-01	Protection CSRF : jeton anti-CSRF ou vérification d'origine sur toute requête modifiant l'état.	M	T
SEC-WEB-02	Content-Security-Policy sans `unsafe-inline` ; en-têtes X-Content-Type-Options et frame-ancestors.	M	E : en-têtes
SEC-WEB-03	Toute sortie utilisateur est encodée ; aucune injection HTML brute dans le frontend.	M	R/T
SEC-WEB-04	Aucun jeton d'authentification dans le `localStorage`.	M	R
SEC-WEB-05	Requêtes JPA paramétrées uniquement ; validation Jakarta Validation de toutes les entrées.	M	R/T
SEC-WEB-06	Le service worker ne met en cache aucune réponse de l'API de documents.	M	E
SEC-WEB-07	Dépendances : analyse de vulnérabilités dans la CI ; correctifs critiques sous 7 jours.	S	R

9.9 Résilience et disponibilité

ID	Exigence	Prio	Vérification
SEC-RES-01	Limitation de débit : 100 requêtes/minute/IP en général, 5 imports/minute/utilisateur.	M	T : charge
SEC-RES-02	Le traitement PDF est exécuté dans une file à concurrence bornée ; une surcharge renvoie 429/503 sans arrêt du service.	M	T
SEC-RES-03	Sauvegarde quotidienne de la base, des documents et des clés (stockées séparément) ; restauration testée.	M	E : essai de restauration
SEC-RES-04	Cibles initiales : RPO $\leq$ 24 h, RTO $\leq$ 4 h, à valider expérimentalement (ce ne sont pas des garanties).	S	E
SEC-RES-05	Un point de santé (health check) expose l'état de la base, du stockage et du service PDF.	S	T
SEC-RES-06	Indicateurs suivis : latence API (95% $<$ 2 s hors traitement PDF), taux d'erreur serveur $<$ 1%.	S	E

10 Traçabilité des exigences

Cas d'abus	Exigences de sécurité	Fonctionnalité	Test prévu
MC-01	SEC-AUTH-02 à 05	EF-01	Force brute, verrouillage
MC-02	SEC-AUTHZ-02, 03, 05	EF-15	Accès croisé entre utilisateurs
MC-03	SEC-DOC-06, SEC-INT-03	EF-06, 12, 17	Campagne de robustesse
MC-04	SEC-INT-02, 03	EF-05, 10	UUID copié dans un autre PDF
MC-05	SEC-DOC-07	EF-13	Comparaison de deux copies
MC-06	SEC-DOC-01 à 05, 08	EF-03, 17	Jeu de PDF piégés
MC-07	SEC-INT-01, 03, 04	EF-07, 14	Modification directe en base
MC-08	SEC-AUD-02, 03	EF-20	Altération d'une ligne de journal
MC-09	SEC-RES-01, 02	EF-03	Test de charge
MC-10	SEC-WEB-01 à 04, SEC-AUTH-06	Frontend	Tests XSS/CSRF
MC-11	SEC-DATA-03 à 05	Transverse	Analyse de secrets
MC-12	SEC-NR-03, SEC-INT-05	EF-18	Cas de correspondance faible

10.1 Récits d'abus (backlog)

Chaque exigence **M** devient une issue GitHub étiquetée `security`. Exemple :

> *En tant que destinataire malveillant, je modifie l'identifiant du document dans l'URL pour télécharger la copie d'un autre.*
> Critère d'acceptation : la requête renvoie 404 et un événement est journalisé (SEC-AUTHZ-02, SEC-AUTHZ-03, SEC-AUD-01).

Une fonctionnalité n'est « terminée » que si ses exigences de sécurité liées passent leurs tests.

11 Gestion et maintenance des exigences

11.1 Cycle de vie

Chaque exigence possède : identifiant, description, priorité, source (cas d'abus), statut (*proposée*, *validée*, *implémentée*, *vérifiée*, *abandonnée*), critère de vérification, version.

Toute modification passe par une pull request mentionnant l'identifiant concerné ; l'historique Git constitue le journal des changements.

11.2 Évolution selon l'agenda du cours

Séance	**Thème**	**Action sur les exigences**
1	Exigences de sécurité	Version 1.0 de ce recueil
2	[À compléter]	Raffinement, revue des valeurs cibles
3	[À compléter]	[À compléter]
...	[À compléter]	Mise à jour du statut et des tests

11.3 Inspection (SQUARE, étape 9)

— Revue croisée des exigences par l'autre membre de l'équipe avant passage au statut *validée*.

— Contrôle : chaque cas d'abus a au moins une exigence ; chaque exigence M a un test défini.

— Réévaluation de la matrice de risques à chaque séance.

11.4 Historique des versions

Version	**Date**	**Modification**
1.0	Séance 1	Création du recueil